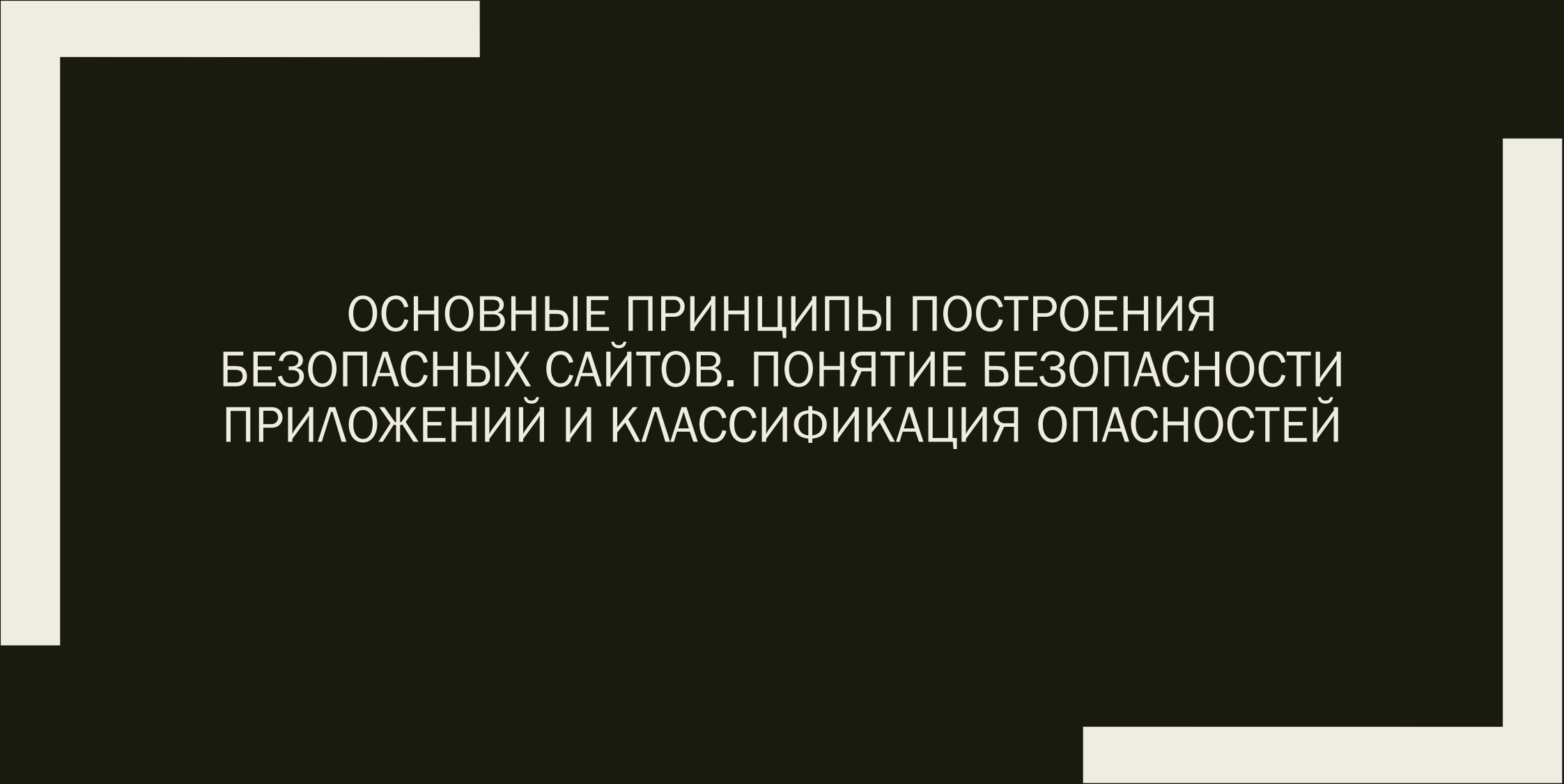




ОСНОВНЫЕ ПРИНЦИПЫ ПОСТРОЕНИЯ БЕЗОПАСНЫХ САЙТОВ. ПОНЯТИЕ БЕЗОПАСНОСТИ ПРИЛОЖЕНИЙ И КЛАССИФИКАЦИЯ ОПАСНОСТЕЙ

Информационная безопасность

В связи с развитием информационных технологий и компьютеризацией экономики одним из важнейших вопросов в деятельности компании становится обеспечение информационной безопасности.

Информация – это один из самых ценных и важных активов любого предприятия, должна быть надлежащим образом защищена.

Информационная безопасность – это сохранение и защита информации, а также ее важнейших элементов, в том числе системы и оборудование, предназначенные для использования, сбережения и передачи этой информации. Другими словами, это набор технологий, стандартов и методов управления, которые необходимы для защиты информационной безопасности.

Цель информационной безопасности

Цель обеспечения информационной безопасности – защитить информационные данные и поддерживающую инфраструктуру от случайного или преднамеренного вмешательства, что может стать причиной потери данных или их несанкционированного изменения. Информационная безопасность помогает обеспечить непрерывность бизнеса.

Принципы информационной безопасности

Для успешного внедрения систем информационной безопасности на предприятии необходимо придерживаться трех главных принципов:

1. **Конфиденциальность.** Это значит **ввести в действие контроль**, чтобы гарантировать достаточный уровень безопасности с данными предприятия, активами и информацией на разных этапах деловых операций для **предотвращения нежелательного или несанкционированного раскрытия**. Конфиденциальность должна поддерживаться при сохранении информации, а также при транзите через рядовые организации независимо от ее формата.

Принципы информационной безопасности

2. **Целостность.** Целостность имеет дело с элементами управления, которые связаны с обеспечением того, чтобы **корпоративная информация была внутренне и внешне последовательной**. Целостность также **гарантирует предотвращение искажения информации**.

Принципы информационной безопасности

3. **Доступность.** Доступность обеспечивает надежный и эффективный доступ к информации уполномоченных лиц. Сетевая среда должна вести себя предсказуемым образом с целью получить доступ к информации и данным, когда это необходимо. **Восстановление системы** по причине сбоя является важным фактором, когда речь идет о доступности информации, и такое восстановление также должно быть обеспечено таким образом, чтобы это не влияло на работу отрицательно.

Контроль информационной безопасности

Нужно понимать, что лишь системный и комплексный подход к защите может обеспечить информационную безопасность. В системе информационной безопасности нужно учитывать все актуальные и вероятные угрозы и уязвимости. Для этого необходим непрерывный контроль в реальном времени. Контроль должен производиться 24/7 и охватывать весь жизненный цикл информации – от момента, когда она поступает в организацию, и до ее уничтожения или потери актуальности.

Выбор и внедрение подходящих видов контроля безопасности поможет организации снизить риск до приемлемых уровней. Выделяют следующие виды контроля:

Виды контроля информационной безопасности

1. **Административный.** Административный вид контроля состоит из утвержденных процедур, стандартов и принципов. Он формирует рамки для ведения бизнеса и управления людьми. Законы и нормативные акты, созданные государственными органами, также являются одним из видов административного контроля. Другие примеры административного контроля включают политику корпоративной безопасности, паролей, найма и дисциплинарные меры.

Виды контроля информационной безопасности

2. **Логический**. Логические **средства управления** (еще называемые техническими средствами контроля) базируются на защите доступа к информационным системам, программном обеспечении, паролях, брандмауэрах, информации для мониторинга и контроле доступа к системам информации.

Виды контроля информационной безопасности

3. **Физический.** Это контроль среды рабочего места и вычислительных средств (отопление и кондиционирование воздуха, дымовые и пожарные сигнализации, противопожарные системы, камеры, баррикады, ограждения, замки, двери и др.).

Угрозы информационной безопасности

Угрозы информационной безопасности можно разделить на следующие:

- Естественные (катаклизмы, независящие от человека: пожары, ураганы, наводнение, удары молнии и т.д.).
- Искусственные, которые также делятся на:
 - *непреднамеренные (совершаются людьми по неосторожности или незнанию);*
 - *преднамеренные (хакерские атаки, противоправные действия конкурентов, месть сотрудников и пр.).*
- Внутренние (источники угрозы, которые находятся внутри системы).
- Внешние (источники угроз за пределами системы)

Угрозы информационной безопасности

Так как угрозы могут по-разному воздействовать на информационную систему, их делят на пассивные (те, которые не изменяют структуру и содержание информации) и активные (те, которые меняют структуру и содержание системы, например, применение специальных программ).

Наиболее опасны преднамеренные угрозы, которые все чаще пополняются новыми разновидностями, что связано, в первую очередь, с компьютеризацией экономики и распространением электронных транзакций. Злоумышленники не стоят на месте, а ищут новые пути получить конфиденциальные данные и нанести потери компании.

Чтобы обезопасить компанию от потери денежных средств и интеллектуальной собственности, необходимо уделять больше внимания информационной безопасности. Это возможно благодаря средствам защиты информации в лице передовых технологий.

Средства защиты информационной безопасности

Средства защиты информационной безопасности — это набор технических приспособлений, устройств, приборов различного характера, которые препятствуют утечке информации и выполняют функцию ее защиты.

Средства защиты информационной безопасности

Средства защиты информации делятся на:

- **Организационные.** Это совокупность организационно-технических (обеспечение компьютерными помещениями, настройка кабельной системы и др.) и организационно-правовых (законодательная база) средств.
- **Программные.** Те программы, которые помогают контролировать, хранить и защищать информацию и доступ к ней.
- **Технические (аппаратные).** Это технические виды устройств, которые защищают информацию от проникновения и утечки.
- **Смешанные аппаратно-программные.** Выполняют функции как аппаратных, так и программных средств.

Средства защиты информационной безопасности

В связи со стремительным развитием ИТ, все более частыми кибератаками, компьютерными вирусами и другими появляющимися угрозами наиболее распространенными и востребованными на сегодняшний день являются программные средства защиты информации.

Виды средств защиты информации

Антивирусные программы — программы, которые борются с компьютерными вирусами и возобновляют зараженные файлы.

Виды средств защиты информации

Облачный антивирус – одно из облачных решений информационной безопасности, что применяет легкое программное обеспечение агента на защищенном компьютере, выгружая большую часть анализа информации в инфраструктуру провайдера. CloudAV – это также решение для эффективного сканирования вирусов на приспособлениях с невысокой вычислительной мощностью для выполнения самих сканирований. Некоторые образцы облачных антивирусных программ – это Panda Cloud Antivirus, CrowdStrike, Cb Defense и Immundet.

Виды средств защиты информации

DLP (Data Leak Prevention) решения – это защита от утечки информации. Предотвращение утечки данных (DLP) представляет собой набор технологий, направленных на предотвращение потери конфиденциальной информации, которая происходит на предприятиях по всему миру. Успешная реализация этой технологии требует значительной подготовки и тщательного технического обслуживания. Предприятия, желающие интегрировать и внедрять DLP, должны быть готовы к значительным усилиям, которые, если они будут выполнены правильно, могут значительно снизить риск для организации.

Виды средств защиты информации

Криптографические системы – преобразование информации таким образом, что ее расшифровка становится возможной только с помощью определенных кодов или шифров. Криптография обеспечивает защиту информации и другими полезными приложениями, включая улучшенные методы проверки подлинности, дайджесты сообщений, цифровые подписи и зашифрованные сетевые коммуникации. Старые, менее безопасные приложения, например Telnet и протокол передачи файлов (FTP), медленно заменяются более безопасными приложениями, такими как Secure Shell (SSH), которые используют зашифрованные сетевые коммуникации. Беспроводная связь может быть зашифрована с использованием таких протоколов, как WPA/WPA2 или более старый (и менее безопасный) WEP.

Виды средств защиты информации

Межсетевые экраны (брандмауэры или файрволы) – устройства контроля доступа в сеть, предназначенные для блокировки и фильтрации сетевого трафика. Брандмауэры обычно классифицируются как сетевые или хост-серверы. Сетевые брандмауэры на базе сети расположены на шлюзовых компьютерах LAN, WAN и интрасетях. Это либо программные устройства, работающие на аппаратных средствах общего назначения, либо аппаратные компьютерные устройства брандмауэра. Брандмауэры предлагают и другие функции для внутренней сети, которую они защищают, например, являются сервером DHCP или VPN для этой сети. Одним из лучших решений как для малых, так и для больших предприятий являются межсетевые экраны CheckPoint.

Виды средств защиты информации

VPN (Virtual Private Network). Виртуальная частная сеть (VPN) дает возможность определить и использовать для передачи и получения информации частную сеть в рамках общедоступной сети. Таким образом, приложения, работающие по VPN, являются надежно защищенными. VPN дает возможность подключиться к внутренней сети на расстоянии. С помощью VPN можно создать общую сеть для территориально отдаленных друг от друга предприятий. Что касается отдельных пользователей сети – они также имеют свои преимущества использования VPN, так как могут защищать собственные действия с помощью VPN, а также избегать территориальные ограничения и использовать прокси-серверы, чтобы скрыть свое местоположение.

Виды средств защиты информации

Proxy-server (Прокси-сервер) – это определенный компьютер или компьютерная программа, которая является связывающим звеном между двумя устройствам, например, такими как компьютер и другой сервер. Прокси-сервер можно установить на одном компьютере вместе с сервером брандмауэра, или же на другом сервере. Плюсы прокси-сервера в том, что его кэш может служить для всех пользователей. Интернет-сайты, которые являются наиболее часто запрашиваемыми, чаще всего находятся в кэше прокси, что несомненно удобно для пользователя. Фиксирование своих взаимодействий прокси-сервером служит полезной функцией для исправления неполадок.

Виды средств защиты информации

Системы мониторинга и управления информационной безопасностью. Чтобы выявлять и реагировать на возникающие угрозы информационной безопасности, используется решение SIEM, которое выполняет сбор и анализ событий из разных источников, таких как межсетевые экраны, антивирусы, IPS, оперативные системы и т.п. Благодаря системе SIEM у компаний появляется возможность централизованно хранить журналы событий и коррелировать их, определяя отклонения, потенциальные угрозы, сбои в работе ИТ-инфраструктуры, кибератаки и т.д.

Требования к системе защиты ИБ

Защита информационных ресурсов должна быть:

1. **Постоянной**. Злоумышленник в любой момент может попытаться обойти модули защиты данных, которые его интересуют.
2. **Целевой**. Информация должна защищаться в рамках определенной цели, которую ставит организация или собственник данных.
3. **Плановой**. Все методы защиты должны соответствовать государственным стандартам, законам и подзаконным актам, которые регулируют вопросы защиты конфиденциальных данных.
4. **Активной**. Мероприятия для поддержки работы и совершенствования системы защиты должны проводиться регулярно.

Требования к системе защиты ИБ

5. **Комплексной.** Использование только отдельных модулей защиты или технических средств недопустимо. Необходимо применять все виды защиты в полной мере, иначе разработанная система будет лишена смысла и экономического основания.

6. **Универсальной.** Средства защиты должны быть выбраны в соответствии с существующими в компании каналами утечки.

7. **Надежной.** Все приемы защиты должны надежно перекрывать возможные пути к охраняемой информации со стороны злоумышленника, независимо от формы представления данных.

Этапы создания и обеспечения системы защиты информации

На первом этапе разрабатывается базовая модель системы, которая будет функционировать в компании. Для этого необходимо проанализировать все виды данных, которые циркулируют в фирме и которые нужно защитить от посягательств со стороны третьих лиц. Планом работы на начальном этапе являются четыре вопроса:

1. Какие источники информации следует защитить?
2. Какова цель получения доступа к защищаемой информации?

Целью может быть ознакомление, изменение, модификация или уничтожение данных. Каждое действие является противоправным, если его выполняет злоумышленник. Ознакомление не приводит к разрушению структуры данных, а модификация и уничтожение приводят к частичной или полной потере информации.

Этапы создания и обеспечения системы защиты информации

3. Что является источником конфиденциальной информации?

Источники в данном случае это люди и информационные ресурсы: документы, флеш-носители, публикации, продукция, компьютерные системы, средства обеспечения трудовой деятельности.

Этапы создания и обеспечения системы защиты информации

4. Способы получения доступа, и как защититься от несанкционированных попыток воздействия на систему?

Различают следующие способы получения доступа:

Несанкционированный доступ – незаконное использование данных;

Утечка – неконтролируемое распространение информации за пределы корпоративной сети. Утечка возникает из-за недочетов, слабых сторон технического канала системы безопасности;

Разглашение – следствие воздействия человеческого фактора. Санкционированные пользователи могут разглашать информацию, чтобы передать конкурентам, или по неосторожности.

Этапы создания и обеспечения системы защиты информации

Второй этап включает разработку системы защиты. Это означает реализовать все выбранные способы, средства и направления защиты данных.

Система строится сразу по нескольким направлениям защиты, на нескольких уровнях, которые взаимодействуют друг с другом для обеспечения надежного контроля информации.

Этапы создания и обеспечения системы защиты информации

Третий, завершающий этап – это поддержка работоспособности системы, регулярный контроль и управление рисками. Важно, чтобы модуль защиты отличался гибкостью и позволял администратору безопасности быстро совершенствовать систему при обнаружении новых потенциальных угроз.

Аппаратная и программная ИБ

Все современные операционные системы оснащены встроенными модулями защиты данных на программном уровне. MAC OS, Windows, Linux, iOS отлично справляются с задачей шифрования данных на диске и в процессе передачи на другие устройства. Однако для создания эффективной работы с конфиденциальной информацией важно использовать дополнительные модули защиты.

Пользовательские ОС не защищают данные в момент передачи по сети, а системы защиты позволяют контролировать информационные потоки, которые циркулируют по корпоративной сети, и хранение данных на серверах.

Аппаратная и программная ИБ

Аппаратно-программный модуль защиты принято разделять на группы, каждая из которых выполняет функцию защиты чувствительной информации:

- **Уровень идентификации** – это комплексная система распознавания пользователей, которая может использовать стандартную или многоуровневую аутентификацию, биометрию (распознавание лица, сканирование отпечатка пальца, запись голоса и прочие приемы).
- **Уровень шифрования** обеспечивает обмен ключами между отправителем и получателем и шифрует/дешифрует все данные системы.

Заключение

Информация очень важна для успешного развития бизнеса, следовательно, нуждается в соответствующей защите. Особенно актуально это стало в бизнес-среде, где на передний план вышли информационные технологии. Так как мы живем в эпоху цифровой экономики, без них рост компании просто невозможен.

Информация сейчас подвергается все большему числу угроз и уязвимостей. Хакерские атаки, перехват данных по сети, воздействие вирусного ПО и прочие угрозы приобретают более изощренный характер и набирают огромный темп. Отсюда возникает необходимость внедрять системы информационной безопасности, которые могли бы защитить данные компании.

На выбор подходящих средств защиты информации влияют многие факторы, включая сферу деятельности компании, ее размер, техническую сторону, а также знания сотрудников в области информационной безопасности.